VERITRAIL Launch & Enhancement Blueprint — v3.0

Enterprise AI Governance: Assess · Register · Control · Shield · Assurance · Agent

Version	3.0 (supersedes v2.0 of 21 October 2026)
Date	21 October 2026
Status	Master document — MVP build in progress; pilots awaiting design partners
Owner	VERITRAIL Product Lead; content: Governance Content Lead
Classification	Internal / design-partner shareable after review

> ***Disclaimer.*** *VERITRAIL supports governance readiness, control implementation and evidence collection. It does not certify ISO/IEC 42001 conformity, guarantee EU AI Act compliance, or replace legal advice. Framework mappings are*
>
> *indicative. EU AI Act applicability dates must be verified against the current Official Journal text and any*
>
> *amendments (the Commission's 2025 "Digital Omnibus" proposals may change high-risk timelines; not verified in this*
>
> *repository).*

0. How to read this document

v3.0 consolidates Blueprint v2.0 and the artefacts built in sprint 1 into one master reference. Each section summarizes the decision and links to the authoritative artefact in the repository (`/work/veritrail`). Where this document and a source file disagree, **the source file wins**:

Topic	Authoritative source
Control IDs, mappings	`content/controls/controls.yaml`
Self-assessment questions and scoring	`content/assessment_templates/maturity_self_assessment.yaml`
Agent tools and permissions	`app/agent/veritrail_agent/tools.py` (`TOOL_REGISTRY`), `config.py`
Runtime policy schema	`app/policy-engine/veritrail_policy/schema.py`, `constants.py`
Interfaces between components	`CONTRIBUTING.md` §3
Architecture and decisions	`docs/TECHNICAL_ARCHITECTURE.md`, `docs/DECISION_LOG.md`

0.1 What is new in v3.0

Area	v2.0	v3.0 enhancement
Control library	Pillars and example controls	**64 published controls** (AO 12, EI 12, GL 12, IS 16, SE 12) with objective, evidence, owner, priority, scope, modules and indicative NIST AI RMF / ISO/IEC 42001 / EU AI Act mappings
Compliance mapping	Indicative statements	**Generated crosswalk** with methodology, coverage statistics, support boundaries per EU AI Act article and an explicit coverage-gap section
Scoring	Weights and levels	**Exact integer scoring rules**, nine critical flags, readiness indicator groups, module and lead rules — interpreted identically by Python and browser engines
Agent	14 tools, 4 journeys	**Tool permission levels, RBAC roles and six sensitive actions** that always route to human approval
Runtime Shield	Decisions and rollout	`veritrail.policy/v1` **schema summary**, decision precedence, lifecycle states, six reference policy packs
Industry packs	Named	**Five packs** with use cases, tier hints consistent with the risk-tier engine, emphasized controls, evidence, regimes (verify with counsel), policy packs, discovery questions
Pilots	Plan and metrics	**Complete Pilot A/B kits**: plans, scorecards (method + data source per metric), onboarding, safeguards, workshop kit, session guide, deep-dive plan, agent protocol, templates, survey, proposal, honest status tracker

Area	v2.0	v3.0 enhancement
Commercial	Pricing models	**Commercial kit**: pricing hypotheses and tiers, seven one-pagers, ROI calculator (tested) with sensitivity, demo scripts, objection guide, case-study rule, 90-day onboarding
Planning	Phases	PRD with requirement IDs and acceptance criteria; dependency-based roadmap with exit criteria (no calendar estimates); 22-item risk register; backlog with honest statuses

---

1. Executive summary

Enterprises are scaling AI — increasingly **agents that act through tools** — while boards, auditors, customers and regulators ask for evidence that AI is governed. Most organizations cannot yet answer: *What AI do we run? Who owns it? How risky is it? Who approved it? What stops an agent misbehaving? Can we prove it?*

VERITRAIL answers with evidence. It combines an operating framework (five pillars, 64 controls, eight assessment domains) with a product suite of six modules — **Assess, Register, Control, Shield, Assurance, Agent** — plus industry packs, organized across six layers from the AI System of Record to Assurance & Evidence.

Go-to-market: land with the fixed-scope **Governance Baseline** (4–6 weeks), expand **Baseline** → **Register** → **Control** → **Shield** → **Assurance** → **Managed Governance Service**; AI-forward builders can enter at **Shield**.

Where we are (21 October 2026):

- Framework content, compliance mapping, industry packs, pilot kits and commercial kit: **built and tested in sprint 1, pending human review**.
- Website, self-assessment, VERITRAIL Agent MVP and Runtime Shield: **in progress — built in sprint 1** by parallel workstreams.
- Pilots and commercial execution: **blocked — require real design partners**. Both pilots are *Not started — awaiting design-partner recruitment*. There are no customers, case studies or measured results, and this document claims none.

---

2. Problem, users and principles

2.1 Personas (detail: `docs/PRODUCT_REQUIREMENTS.md` §2)

Head of AI Governance / CAIO · CRO / second line · CISO · Platform/AI engineering lead · Legal / DPO · Internal audit · Business/product owner · Website evaluator · VERITRAIL delivery consultant.

2.2 Governance non-negotiables (apply to every component)

1. **Cite or stay silent.** Every material recommendation cites an VERITRAIL control ID (and where relevant a question ID, policy ID+version, evidence ID or a mapping from the control). Otherwise output exactly: `No supporting evidence or framework source is available.`
2. **Evidence labels:** Verified (named reviewer) · User-asserted · Inferred · Missing evidence · Critical gap.
3. **No compliance claims.** Never state an organization or system is compliant, certified or regulator-approved; use readiness, alignment indicators, evidence. Text is checked with `find_prohibited_claims()`.
4. **Human approval** for changing a risk tier, approving an exception, changing production runtime policy, exporting sensitive evidence and sending external communications. These create pending approvals and never self-execute.
5. **Redact first** before any external LLM call or log write.
6. **Audit** material actions in a hash-chained log with trace IDs.
7. **Least privilege**: every agent tool declares a permission level; write tools create drafts.

---

3. The VERITRAIL Framework

Full text: `content/veritrail_framework.md`, `content/pillars.md`, `content/maturity_model.md`.

3.1 Five pillars

ID	Pillar	Governing question
AO	Accountability & Operating Model	Who owns AI risk, who decides, how is governance resourced?
EI	Enterprise AI Inventory	What AI do we have, who owns it, how risky is it?
GL	Governance & Lifecycle Control	What gates does each system pass from idea to retirement?
IS	Integrity, Safety & Security	Is the AI fair, safe, secure and contained at runtime?
SE	Stewardship, Evidence & Assurance	Can we prove controls operate, learn from incidents and improve?

3.2 Six layers and modules

#	Layer	Key controls	Module
1	AI System of Record	EI-01 … EI-12, AO-09	Register
2	Assessment & Risk Engine	AO-04, AO-10, EI-02, GL-01, GL-02, IS-03, IS-05, IS-06	Assess, Agent
3	Policy & Control Library	AO-01, AO-07, AO-08, AO-10	Control
4	Lifecycle Governance	GL-03, GL-04, GL-07, GL-09, GL-10, GL-12	Control
5	Runtime Shield	IS-04, IS-11, IS-12, IS-13, IS-15, IS-16	Shield
6	Assurance & Evidence	SE-01 … SE-12, GL-08	Assurance

The **VERITRAIL Agent** works across all layers; **industry packs** overlay sector use cases and evidence.

3.3 Risk tiers

Prohibited-review · High · Medium · Low. Tiers are computed by `calculate_risk_tier` with a factor-by-factor rationale, labelled **Inferred**, and require human confirmation (EI-02). Approval authority and review cadence by tier: Low — Product Owner with AI CoE review, 24 months; Medium — AI Risk Lead, 12 months; High — AI Governance Forum, 6 months; Prohibited-review — Legal and AI Governance Forum (default: do not proceed).

3.4 Lifecycle

Intake (EI-12) → Triage (GL-01, AO-10, EI-02) → Assess (GL-02, IS-03, IS-01) → Approve (GL-03, GL-10) → Go-live (GL-07) → Operate & monitor (GL-08, SE-12, IS-12, SE-04, SE-08) → Change (GL-04) → Periodic review (GL-12) → Retire (GL-09).

---

4. Control library (v1.0.0, 64 controls)

Source: `content/controls/controls.yaml`. Mappings are indicative; see §5.

ID	Control	Pillar	Priority	Applies to	Modules	Owner
AO-01	AI governance policy	AO	critical	all	Control	Chief AI Officer / AI Governance Lead
AO-02	Executive accountability and AI governance forum	AO	critical	all	Control	Executive sponsor (CIO/CRO/COO)
AO-03	AI roles, responsibilities and RACI	AO	high	all	Control	AI Governance Lead
AO-04	AI risk appetite and tolerance	AO	high	all	Control, Assess	Chief Risk Officer
AO-05	AI literacy and role-based training	AO	high	all	Control	HR / Learning lead with AI Governance Lead
AO-06	Escalation paths and decision rights	AO	high	all	Control	AI Governance Lead
AO-07	Regulatory and contractual obligations register	AO	high	all	Control	Legal / Compliance
AO-08	Responsible AI principles and objectives	AO	medium	all	Control	AI Governance Lead

ID	Control	Pillar	Priority	Applies to	Modules	Owner
AO-09	Third-party AI accountability	AO	medium	third_party	Register, Control	Procurement / Vendor Risk
AO-10	Prohibited and restricted AI use policy	AO	critical	all	Control, Assess	Legal / AI Governance Lead
AO-11	Stakeholder engagement and feedback	AO	medium	high_risk	Control, Assurance	Product Owner
AO-12	Governance resourcing	AO	medium	all	Control	Executive sponsor
EI-01	Enterprise AI inventory (system of record)	EI	critical	all	Register	AI Governance Lead / CIO office
EI-02	AI risk classification and tiering	EI	critical	all	Register, Assess	AI Risk Lead
EI-03	Accountable owner per AI system	EI	critical	all	Register	Business unit leaders
EI-04	Intended purpose and context of use	EI	high	all	Register, Assess	Product Owner
EI-05	Model, prompt and component registry	EI	high	all	Register	ML / Platform Engineering Lead
EI-06	Data source and lineage registry	EI	high	all	Register	Data Owner / CDO office
EI-07	Agent and tool registry	EI	critical	agentic	Register, Shield	Platform Engineering Lead
EI-08	Third-party and vendor AI inventory	EI	high	third_party	Register	Procurement / Vendor Risk
EI-09	Shadow AI discovery	EI	medium	all	Register	CISO / IT Asset Management
EI-10	Dependency and integration mapping	EI	medium	high_risk	Register	Enterprise Architecture
EI-11	Inventory attestation and recertification	EI	medium	all	Register, Assurance	AI Governance Lead
EI-12	Use-case intake register	EI	high	all	Register, Assess	AI CoE
GL-01	Intake triage workflow	GL	high	all	Assess, Control	AI CoE
GL-02	Pre-deployment risk and impact assessment	GL	critical	all	Assess	AI Risk Lead
GL-03	Risk-tiered approval gates	GL	critical	all	Control	AI Governance Forum
GL-04	Change management and reassessment triggers	GL	high	all	Control	Engineering / Change Advisory Board
GL-05	Pre-release validation and testing	GL	high	all	Assess, Assurance	QA / ML Engineering
GL-06	Technical documentation	GL	high	high_risk	Control, Assurance	Product / ML Engineering
GL-07	Deployment conditions and go-live readiness	GL	high	all	Control	Product Owner
GL-08	Post-deployment monitoring	GL	high	all	Assurance	ML Ops / Product Owner
GL-09	Retirement and decommissioning	GL	medium	all	Control, Register	Product Owner
GL-10	Exceptions and risk acceptance	GL	high	all	Control	AI Governance Forum
GL-11	Vendor AI due diligence and contract controls	GL	high	third_party	Assess, Control	Procurement / Vendor Risk
GL-12	Periodic review and recertification	GL	medium	all	Control, Assurance	AI Risk Lead
IS-01	AI threat modelling	IS	high	all	Shield, Assess	CISO / Security Architecture

ID	Control	Pillar	Priority	Applies to	Modules	Owner
IS-02	Data governance and quality	IS	high	all	Control	Data Owner
IS-03	Privacy assessment and data minimisation	IS	critical	all	Assess, Control	DPO / Privacy Lead
IS-04	Sensitive data redaction and masking	IS	critical	genai	Shield	Platform Engineering / Privacy Lead
IS-05	Bias and fairness testing	IS	high	high_risk	Assess, Assurance	Responsible AI Lead / Data Science
IS-06	Safety and harm evaluation	IS	high	high_risk	Assess	Responsible AI Lead
IS-07	Accuracy and robustness testing	IS	high	high_risk	Assess, Assurance	ML Engineering
IS-08	Transparency and AI disclosures	IS	high	all	Control	Product Owner / Legal
IS-09	Human oversight design	IS	critical	high_risk	Control, Shield	Business Owner
IS-10	Secure model and prompt supply chain	IS	high	genai	Shield	Security Architecture
IS-11	Least-privilege tool access	IS	critical	agentic	Shield	Platform Engineering / IAM
IS-12	Runtime guardrails and policy enforcement	IS	high	genai	Shield	Platform Engineering / Security
IS-13	Human approval for high-impact actions	IS	critical	agentic	Shield, Control	Business Owner
IS-14	Prompt-injection and data-leakage testing	IS	critical	genai	Shield, Assess	Security Testing / Red Team
IS-15	Kill switch and rollback	IS	critical	all	Shield	Platform Engineering / SRE
IS-16	Rate, budget and resource limits	IS	medium	genai	Shield	Platform Engineering / FinOps
SE-01	Control testing programme	SE	high	all	Assurance	Second line / Compliance Testing
SE-02	Evidence repository and retention	SE	high	all	Assurance	AI Governance Lead
SE-03	Governance metrics and leadership reporting	SE	medium	all	Assurance	AI Governance Lead
SE-04	AI incident management and reporting	SE	high	all	Assurance, Shield	CISO / Operational Risk
SE-05	Audit-ready evidence packs	SE	high	high_risk	Assurance	AI Governance Lead
SE-06	Corrective action and continuous improvement	SE	medium	all	Assurance, Control	AI Governance Lead
SE-07	Management review	SE	medium	all	Assurance	Executive sponsor
SE-08	Immutable action logging	SE	critical	all	Shield, Assurance	Platform Engineering / Security Operations
SE-09	Post-market monitoring plan	SE	high	high_risk	Assurance	Product Owner
SE-10	Independent review and internal audit	SE	medium	all	Assurance	Internal Audit
SE-11	Stakeholder transparency reporting	SE	medium	high_risk	Assurance	Product Owner
SE-12	Model performance and drift monitoring	SE	high	all	Assurance	ML Ops

Cross-pillar sets: agent governance — EI-07, IS-01, IS-11, IS-12, IS-13, IS-14, IS-15, IS-16, SE-08; evidence & audit — GL-06, SE-01, SE-02, SE-05, SE-08, EI-11; third-party AI — AO-09, EI-08, GL-11, IS-10.

5. Compliance mapping (indicative) and coverage gaps

Source: `docs/COMPLIANCE_MAPPING.md`, generated by `docs/tools/gen_compliance_mapping.py` from controls.yaml.

Coverage measure (v1.0.0)	Value
Controls with NIST AI RMF / ISO/IEC 42001 mappings	64 / 64
Controls with EU AI Act mappings	58
NIST AI RMF subcategories referenced	54 of 72
ISO/IEC 42001 clauses / Annex A controls referenced	23 of 28 / 37 of 38 (reference lists)
EU AI Act articles referenced	22

VERITRAIL does not cover: EU AI Act conformity assessment by notified bodies (Art. 43), EU declaration of conformity and CE marking (Arts. 47–48), registration in the EU database (Arts. 49, 71), GPAI provider obligations (Chapter V), role-specific provider/importer/distributor obligations, serious-incident filing with authorities, ISO/IEC 42001 certification audits, and legal determinations of applicability or classification. For articles VERITRAIL maps but cannot discharge (e.g. Art. 43, 49, 72, 73), the crosswalk states the **support boundary** explicitly.

EU AI Act timeline: as originally published, application is staggered from 2 February 2025 to 2 August 2027. These dates must be verified against the current Official Journal text and amendments before any use; possible changes from the 2025 Digital Omnibus proposals have not been verified in this repository.

---

6. Maturity self-assessment and scoring rules

Source: `content/assessment_templates/maturity_self_assessment.yaml` (VERITRAIL-SA-MATURITY v1.0.0); explanation in `content/maturity_model.md`.

Domain	Weight	Questions
Strategy & Accountability	12	STR-Q1–Q3
AI Inventory & Visibility	14	INV-Q1–Q3
Risk Management & Lifecycle	14	RSK-Q1–Q3
Data & Privacy	12	DAT-Q1–Q3
Security & Resilience	14	SEC-Q1–Q3
Fairness, Safety & Transparency	12	FST-Q1–Q3
Human Oversight & Operations	12	HUM-Q1–Q3
Assurance, Evidence & Improvement	10	ASR-Q1–Q3

Scale: 1 Not started · 2 Initial/ad hoc · 3 Defined for some systems · 4 Consistently implemented · 5 Measured, automated, continuously improved.

Formulas (integer arithmetic, identical in Python and JS):

```
domain_score  = round_half_up_1dp( Σ answers × 100 / (5 × n) )
overall_score = round_half_up_1dp( Σ_d Σ answers_d × weight_d / (5 × n_d) )   (from unrounded domain values)
round_half_up_1dp(num/den) = floor((20·num + den) / (2·den)) / 10
```

Levels: Initial 0–39.9 · Developing 40–59.9 · Defined 60–74.9 · Managed 75–89.9 · Optimized 90–100 (minimum achievable score 20.0).

Derived outputs: strengths (score ≥ 4, top 5); gaps (≤ 3, top 5); 30/60/90 plan (1–2 → 30, 3 → 60, 4 → 90 days); up to 10 recommended controls (from flags then gaps); framework readiness indicators banded Limited (<50) / Partial (50–74.9) / Substantial (≥75); recommended modules; internal lead tags.

Critical flags (all labelled Critical gap): FLAG-NO-INVENTORY (INV-Q1 ≤ 2; EI-01, EI-09) · FLAG-NO-PREDEPLOY-ASSESSMENT (RSK-Q1 ≤ 2; GL-02, GL-03) · FLAG-SENSITIVE-DATA-EXPOSURE (DAT-Q3 ≤ 2; IS-04, IS-03) · FLAG-AGENTS-UNTESTED (SEC-Q2 ≤ 2 and uses agents; IS-14, IS-11, IS-12) · FLAG-NO-KILL-SWITCH (SEC-Q3 ≤ 2; IS-15) · FLAG-NO-HUMAN-OVERSIGHT (HUM-Q1 ≤ 2; IS-09, IS-13) · FLAG-NO-EVIDENCE (ASR-Q2 ≤ 2; SE-05, SE-08) · FLAG-EU-TRANSPARENCY (FST-Q2 ≤ 2 and EU operations; IS-08) · FLAG-NO-POLICY (STR-Q1 ≤ 1; AO-01, AO-02).

Worked example (synthetic): answers summing per domain to 8, 7, 7, 9, 8, 7, 8, 7 give an overall score of 254/5 = **50.8** → **Developing** (see `content/maturity_model.md` §4.3).

All self-assessment results are **User-asserted**; pilots and Baselines add a **validated** score alongside.

7. VERITRAIL Agent

Design: `docs/TECHNICAL_ARCHITECTURE.md` (agent section) and `app/agent/veritrail_agent/`. Deterministic-first; an LLM is optional and used for phrasing only (DEC-0008).

Journeys: Ask VERITRAIL · Guided assessment · Gap analysis · Report generation.

Permission levels: read < compute < create_draft < write_confirm < approval_required. `create_draft` tools only create draft/in-progress records; `write_confirm` tools need explicit user confirmation or return a preview; `approval_required` tools execute only with an approved, single-use approval resolved by a different user holding an approver role.

7.1 The 14 tools

#	Tool	Permission	Requires approval	Minimum role	Purpose
1	`search_veritrail_knowledge`	read	No	anonymous	BM25 retrieval over controls, assessment templates, policy/industry packs and compliance mapping docs.
2	`search_ai_inventory`	read	No	viewer	Search AI system records.
3	`create_ai_system_record`	create_draft	No	assessor	Create a draft AI system record.
4	`start_assessment`	create_draft	No	assessor	Start a use-case assessment (risk tier + applicable modules).
5	`submit_assessment_response`	create_draft	No	assessor	Record an answer and evidence references (User-asserted).
6	`calculate_risk_tier`	compute	No	anonymous	Preliminary, explainable risk tier (Inferred; requires human confirmation).
7	`identify_gaps`	compute	No	viewer	Classify findings by evidence status and severity; owners and due dates.
8	`recommend_controls`	compute	No	anonymous	Recommend VERITRAIL controls from gaps or from a profile.
9	`create_remediation_task`	write_confirm	No	assessor	Create remediation tasks (requires explicit user confirmation).
10	`generate_report`	create_draft	No	assessor	Generate a draft readiness report (Markdown, PDF, CSV gap register, JSON).
11	`search_runtime_logs`	read	No	assessor	Search runtime guardrail decision logs (redacted).
12	`draft_runtime_policy`	create_draft	No	assessor	Draft a runtime guardrail policy (draft, observe mode, not active) via VERITRAIL Shield.
13	`request_human_approval`	create_draft	No	assessor	Create a pending approval for a sensitive action (never self-executes).
14	`export_evidence_pack`	approval_required	Yes	assessor	Export an evidence pack — only with an approved, single-use approval.

7.2 Roles

Role	Permission levels
anonymous, viewer	read, compute
assessor, approver, admin	read, compute, create_draft, write_confirm, approval_required

Only **approver** and **admin** may resolve approvals (never their own) or mark evidence as reviewed (making it Verified).

7.3 Sensitive actions (always via `request_human_approval`)

Change a risk tier · Confirm an inferred risk tier · Approve a governance exception · Activate or change a production runtime policy · Export a sensitive evidence pack · Send an external communication.

8. Runtime Shield and policy-as-code

Design: `docs/RUNTIME_SHIELD_DESIGN.md` (shield workstream), `app/policy-engine/`, `app/runtime-shield/`. Tagline: **AI proposes. VERITRAIL evaluates. Approved actions execute.**

8.1 Decisions and precedence

Decision	Precedence	Effect
DENY	100	Block
ESCALATE	80	Block and route to a human queue
RATE_LIMIT	70	Block until limits reset
REQUIRE_HUMAN_APPROVAL	60	Hold until a named approver decides
REDACT	40	Permit with sensitive data masked
TRANSFORM	30	Permit with output transformed (append_disclosure, strip_unapproved_urls, truncate)
ALLOW	0	Permit

8.2 Rollout modes

Mode	Behaviour
Observe	Log would-be decision; always allow; payload untouched
Warn	Allow; warning flag when would-be ≠ ALLOW
Protect	Apply REDACT/TRANSFORM; never block
Enforce	Full decisions
Contain	Kill switch active for the policy scope: deny everything

8.3 Policy schema summary (`veritrail.policy/v1`)

Section	Purpose (key fields)
Identity of the policy	`schema_version`, `policy_id`, `policy_name`, `description`, `version` (semver), `owner`
Lifecycle	`status`: draft → in_review → approved → active → retired; `change_history`; `approval` (required approver roles, min approvers, separation of duties)
Scope	`applies_to`: agent_name, environment (dev/test/staging/production), risk_tier, tenant, model
Rollout	`rollout.mode` (observe/warn/protect/enforce/contain), `exit_criteria`; `shadow_mode`
Caller identity	`identity`: required claims, allowed roles/issuers, tenant binding
Tools	`tools.default_action` (DENY, ESCALATE or REQUIRE_HUMAN_APPROVAL — never ALLOW), `deny_list`, `rules` (tool, operation read/write/delete/external_send/payment/export, action, scopes, parameter constraints, conditions, per-session caps, citations)
Content	`content`: max input size, PII redaction, prompt-injection and jailbreak detection, transforms
Limits	`limits`: requests/minute, tool calls/session, tokens/day, cost/month, action on breach, alert threshold
Logging	`logging`: immutable audit; prompt/response/tool-param logging levels none/metadata/redacted only (raw unsupported); sink
Containment	`kill_switch` (scopes agent/tool/model/tenant, authorized roles, target time-to-disable); `rollback`
Evidence	`evidence_retention_days`; `citations` (VERITRAIL control IDs; every evaluation also cites IS-12 and SE-08)

High-impact operations: delete, external_send, payment, export (delete and payment are irreversible).

8.4 Reference policy packs (`content/policy_packs/`)

`pack-baseline` · `pack-customer-support-agent` · `pack-financial-operations-agent` · `pack-healthcare-clinical-documentation` · `pack-coding-devops-agent` · `pack-internal-rag-knowledge-assistant`. All are drafts in Observe mode; thresholds are illustrative.

8.5 Runtime Shield Advisor

Input: system profile. Output: risk profile, tool matrix, data handling, approval rules, limits, monitoring, incident response, rollout plan, citations and a draft policy (YAML + JSON) that validates against the schema (`POST /api/shield/advise`).

9. Website and conversion

Plan: `docs/WEBSITE_CONTENT_PLAN.md`; pages: `content/website_pages/`. Sections: home, framework (incl. generated control library), solutions (6 modules), compliance (overview, NIST AI RMF, ISO/IEC 42001, EU AI Act readiness, gap-analysis method), industries (5), tools (maturity self-assessment, guardrail generator, Ask VERITRAIL, risk triage; two planned tools with waitlist), resources (blueprint, templates, policy packs, runbooks, blog, case studies), contact (Baseline, demo, newsletter, design-partner programme), legal. No cookies, trackers or third-party CDNs.

Conversion paths: assessment-led (primary) · Baseline-led · guardrails-led · content-led · design-partner.

10. Industry packs

Source: `content/industry_packs/*.yaml` (v1.0.0, draft for pilot validation). Each pack: priority use cases with default risk-tier hints (consistent with the risk-tier engine; confirmed per system by a human), emphasized controls, additional evidence, sector regimes to consider (described generally, **verify with counsel**), recommended policy packs (available or proposed) and pilot discovery questions.

Pack	Example High-tier use cases	Emphasized controls (sample)
Healthcare & Pharma	Clinical decision support; ambient scribing; prior-authorization agents	IS-03, IS-04, IS-09, IS-07, GL-04, SE-09
BFSI	Credit decisioning; life/health insurance pricing; payments agents	EI-02, GL-02, IS-05, IS-13, GL-11, SE-12
GCC & IT Services	AIOps agents; HR screening	AO-09, AO-07, EI-07, IS-11, EI-09, SE-05
SaaS & AI Product	Customer-facing autonomous agents; AI features used for consequential decisions	IS-14, IS-11, IS-12, GL-04, SE-11
Public Sector	Benefits eligibility; fraud detection; education assessment (law-enforcement analytics → Prohibited-review)	GL-02, AO-10, IS-09, IS-05, SE-11

11. Pilots

Playbook: `docs/PILOT_PLAYBOOK.md`; kits: `content/pilots/`. **Status: both pilots Not started — awaiting design-partner recruitment.**

	Pilot A	Pilot B
Partner	Regulated enterprise, 20–100 AI systems	AI-forward SaaS / GCC / enterprise with LLM apps and agents
Focus	Inventory, maturity, compliance evidence (readiness), workflow	Agent governance, runtime guardrails, developer adoption, policy-as-code

Six-week plan: W1 kick-off, scope, data access → W2 inventory workshops → W3 maturity + evidence → W4 deep-dives (5 systems) + up to 2 agent reviews → W5 gap analysis, control mapping, runtime recommendations → W6 executive readout, feedback, proposal. 4-week compressed variant available.

Success metrics: M1 ≥ 25 AI systems registered · M2 100% of High-tier systems assessed · M3 ≥ 70% agent-assisted assessment completion · M4 ≥ 2 runtime policies drafted · M5 executive report accepted · M6 follow-on commercial discussion initiated. Each has a defined measurement method and data source in the scorecards.

Kit contents (per pilot): plan · scorecard (MD + CSV) · onboarding checklist · data-access & privacy safeguards (metadata-only default, redaction, NDA/DPA, retention/deletion, access roles, no production data into external LLMs) · inventory workshop kit (agenda, facilitator script, intake CSV aligned to the risk-tier engine) · maturity session guide · deep-dive plan (5 systems) · agent review protocol (≤ 2) · gap register CSV · remediation roadmap · Runtime Shield recommendations · executive readiness report · feedback survey (Likert + open; framework clarity, assessment length/credibility, agent quality/citations/hallucination resistance, report usefulness, runtime practicality, integration barriers, willingness to pay and pricing preference) · commercial follow-on proposal.

Recruitment: must-have criteria, Pilot A/B specifics, weighted qualification scorecard (max 48; ≥ 32 qualify), outreach sequence and funnel tracker in `content/pilots/pilot_status_tracker.md`.

12. Commercial kit

Kit: `content/commercial/`. **All prices are hypotheses to validate in pilots** — not quotes or market data.

Module	Pricing model	Illustrative range (hypothesis, USD)
Governance Baseline	Fixed fee per engagement	25k – 60k
Register	Per AI system / yr + platform minimum	150 – 400 per system; min 15k – 25k
Control	Per governance user or per BU / yr	1.2k – 3k per user or 10k – 25k per BU
Shield	Per environment + per agent; optional usage	12k – 30k per environment; 2k – 6k per extra agent
Assurance	Enterprise subscription	40k – 120k / yr
Agent	Premium uplift or usage-based	+20% – 30%
Industry packs	Add-on per pack	8k – 20k / yr
Managed Governance Service	Monthly retainer	8k – 25k / month

Packaged tiers (hypotheses): Essentials · Professional · Enterprise · Shield-first · Managed.

ROI calculator (`content/commercial/roi_calculator.py`, tested): inputs for AI systems, assessment hours, hourly cost, audit-prep hours, approval cycle days, incident exposure; every line shows its formula and every assumption is labelled *Customer input*, *Customer estimate* or *VERITRAIL hypothesis — validate in pilot*. The synthetic worked example shows that efficiency savings alone may not cover year-1 cost at 40 systems — the case depends on time-to-value and risk reduction, which pilots must measure. Present ranges, never a single headline number.

Other assets: seven one-pagers (Baseline, Register, Control, Shield, Assurance, Agent, industry packs) · pilot-to-platform proposal · 20/45-minute demo scripts (website → self-assessment → Agent → Shield Advisor → report) · objection-handling guide · case-study template (**no publication without customer written approval and verified metrics**) · 90-day onboarding plan.

13. Go-to-market

Plan: `docs/GTM_PLAN.md`. ICP-1 regulated enterprise (Pilot A), ICP-2 AI-forward builder (Pilot B), ICP-3 mid-market regulated (nurture). Positioning: evidence-first AI governance readiness and runtime assurance. Launch stages L0 ready to recruit → L1 recruitment → L2 pilots → L3 validated launch → L4 scale, governed by exit criteria.

Lead qualification uses the self-assessment `lead_rules` tags — `baseline_priority` (score < 60), `platform_candidate` (10+ AI systems), `shield_candidate` (uses agents), `compliance_led` (regulated sector or EU), `register_opportunity` (FLAG-NO-INVENTORY), `assurance_opportunity` (FLAG-NO-EVIDENCE) — with routing, SLAs and an additive score (≥ 6 SQL, 3–5 MQL). Tags are never shown to respondents.

14. Roadmap

Plan: `docs/ROADMAP.md` (sequenced increments, dependency map, definitions of done, exit criteria; no calendar estimates).

Phase	Increment	Status
0	Framework & content foundation	Built in sprint 1 — pending review
1	Website	In progress — built in sprint 1
2	Self-assessment & lead capture	In progress — built in sprint 1
3	VERITRAIL Agent MVP	In progress — built in sprint 1
4	Runtime Shield	In progress — built in sprint 1
5	Design-partner pilots	Blocked — requires real design partners
6	Commercial launch & GTM	Blocked — requires real design partners/customers
7+	Platform expansion	Scope set by pilot evidence

Backlog: `docs/BACKLOG.md` (epics E0–E7). Requirements: `docs/PRODUCT_REQUIREMENTS.md`.

15. Risks

Register: `docs/RISK_REGISTER.md` (22 risks with likelihood, impact, owner, mitigation, indicators, status).

ID	Risk	Rating	Key mitigation
R-01	Sensitive-data sharing	High	Metadata-only; redaction first; no production data to external LLMs
R-02	Unsupported compliance advice	High	Citation-first; claim checks; disclaimers; agent evaluation
R-03	Assessment too long	Medium	24 questions, instant result, agent-guided option
R-04	Runtime friction	Medium	Observe → Warn → Protect → Enforce rollout
R-05	Pilot scope creep	Medium	Scope note; swap-or-defer rule
R-06	Low conversion	High	Qualification; Week 6 proposal; conversion credit
R-07	Outdated regulatory content	Medium	Quarterly review; verify-against-Official-Journal caveat
R-12	Design-partner recruitment fails	High	Warm intros; lead tags; partner value
R-13	Self-report optimism bias	High	Validated score alongside self-reported
R-15	Over-claiming in sales/marketing	High	Banned phrases; case-study approval rule

16. Team roles

Role	Accountabilities
Product Lead	PRD, roadmap, backlog, risk register custody, pilot learning loop
Governance Content Lead	Control library, framework docs, mappings, industry packs, claim and citation rules, quarterly review
Enterprise Architect / Orchestrator	Architecture, assessment engine, reports, API, integration contracts
AI/Agent Engineer	VERITRAIL Agent, tools, evaluation suite, injection resistance
Shield Lead / Security Engineer	Policy engine, Shield Advisor, policy packs, audit log, security testing
Web / Content Engineer	Website generator, pages, SEO, accessibility
Delivery Lead	Pilots and Governance Baselines, scorecards, safeguards
Commercial / GTM Lead	Pricing hypotheses, recruitment, proposals, GTM plan
Security & Privacy Lead	Safeguards, DPA, redaction, data handling
Legal counsel (advisor)	Regulatory statements, mapping disclaimers, privacy notice and terms

17. Limitations and honesty statement

- VERITRAIL has no customers, pilots in progress, case studies or measured outcomes as of 21 October 2026.
- Pricing, ROI effect sizes and SEO keyword priorities are hypotheses.
- Framework mappings are VERITRAIL interpretations, not official crosswalks; coverage gaps are listed.

- Regulatory dates and sector regimes must be verified with counsel against current official texts.
- Runtime detectors are pattern- and policy-based and will not catch everything; pair with adversarial testing (IS-14).
- Self-assessment results are self-reported; validated scores require evidence review by named humans.

18. Repository artefact index

Area	Path
Contributing contract	`CONTRIBUTING.md`
Control library	`content/controls/controls.yaml`
Self-assessment template	`content/assessment_templates/maturity_self_assessment.yaml`
Use-case question bank	`content/assessment_templates/use_case_assessment.yaml`
Framework docs	`content/veritrail_framework.md`, `content/pillars.md`, `content/maturity_model.md`
Industry packs	`content/industry_packs/{healthcare_pharma,bfsi,gcc_it_services,saas_product,public_sector}.yaml`
Policy packs	`content/policy_packs/*.yaml`
Website pages	`content/website_pages/*.md`; generator `app/website/`
Pilot kits	`content/pilots/` (README, tracker, pilot_a/, pilot_b/, templates/)
Commercial kit	`content/commercial/` (pricing, one_pagers/, ROI calculator + worked example, demo, objections, case study, onboarding, proposal)
Compliance mapping	`docs/COMPLIANCE_MAPPING.md` (generator `docs/tools/gen_compliance_mapping.py`)
Planning docs	`docs/PRODUCT_REQUIREMENTS.md`, `docs/ROADMAP.md`, `docs/BACKLOG.md`, `docs/RISK_REGISTER.md`, `docs/GTM_PLAN.md`, `docs/WEBSITE_CONTENT_PLAN.md`, `docs/PILOT_PLAYBOOK.md`
Technical docs (other workstreams)	`docs/TECHNICAL_ARCHITECTURE.md`, `docs/API_SPECIFICATION.md`, `docs/DECISION_LOG.md`, `docs/DATA_MODEL.md`, `docs/AGENT_DESIGN.md`, `docs/RUNTIME_SHIELD_DESIGN.md`, `docs/STATUS.md`
Code	`app/common`, `app/assessment-engine`, `app/reports`, `app/agent`, `app/policy-engine`, `app/runtime-shield`, `app/api`, `app/admin`, `app/website`
Tests	`tests/unit`, `tests/integration`, `tests/policy-engine`, `tests/security`, `tests/agent-evaluation`
Sample outputs (synthetic)	`output/sample_reports/`

VERITRAIL supports governance readiness, control implementation and evidence collection. It does not certify ISO/IEC 42001 conformity, guarantee EU AI Act compliance, or replace legal advice. Framework mappings are indicative.